

المدرسة الوطنية للعلوم التطبيقية
+ⵍⵉⵎⵎⵓⵏ ⵉⵏⵓⵙⵓⵔ ⵉⵏⵓⵙⵓⵔ ⵉⵏⵓⵙⵓⵔ
École Nationale des Sciences Appliquées d'Oujda



جامعة محمد الأول
+ⵍⵉⵎⵎⵓⵏ ⵉⵏⵓⵙⵓⵔ ⵉⵏⵓⵙⵓⵔ ⵉⵏⵓⵙⵓⵔ
UNIVERSITE MOHAMMED PREMIER OUJDA

UNIVERSITÉ MOHAMMED PREMIER

ÉCOLE NATIONALE DES SCIENCES APPLIQUÉES D'OUJDA

Filière : Management et Gouvernance des Systèmes d'Information (MGSI)

RAPPORT DE PROJET DE FIN D'ANNÉE

Conception et Mise en Œuvre d'un Centre d'Opérations de Sécurité (SOC) Automatisé Augmenté par l'Intelligence Artificielle

Aligné sur les normes ISO 27001 / ISO 27005

Réalisé par :

Ilias AMRANI

Encadré par :

M. Jawad OUBAHA

Année Universitaire : 2025 - 2026

TABLE DES MATIÈRES

TABLE DES MATIÈRES.....	2
REMERCIEMENTS.....	4
RÉSUMÉ.....	4
CHAPITRE 1 : INTRODUCTION ET CONTEXTE.....	6
1.1 Contexte Général.....	6
1.2 Problématique.....	6
1.3 Objectifs du Projet.....	6
1.4 Périmètre et Portée.....	7
1.5 Structure du Rapport.....	7
CHAPITRE 2 : ÉTAT DE L'ART ET ÉTUDE DE L'EXISTANT.....	8
2.1 Évolution des SOC et de l'Automatisation.....	8
2.2 Comparaison des Solutions SIEM.....	8
2.3 Comparaison des Plateformes SOAR.....	9
2.4 L'Intelligence Artificielle dans les SOC Modernes.....	9
2.5 Positionnement du Projet.....	10
CHAPITRE 3 : ARCHITECTURE GLOBALE ET CONCEPTION TECHNIQUE.....	11
3.1 Principes Architecturaux et Justification des Choix.....	11
3.2 Décomposition en Zones de Sécurité.....	11
3.3 Topologie Réseau.....	12
3.4 Flux de Données – Architecture de Traitement.....	12
CHAPITRE 4 : DESCRIPTION APPROFONDIE DES OUTILS ET TECHNOLOGIES.....	14
4.1 Wazuh SIEM / XDR.....	14
4.1.1 Architecture de Déploiement.....	14
4.1.2 Composants Utilisés.....	14
4.1.3 Règles SOCFortress.....	15
4.2 Sysmon (System Monitor).....	16
4.3 n8n – Plateforme SOAR.....	17
4.4 Groq API et Modèle LLaMA 3.1.....	17
4.4.1 Framework de Prompt en 10 Sections.....	17
4.5 IRIS DFIR.....	18
4.6 Plateformes de Threat Intelligence.....	19
4.6.1 AbuseIPDB.....	19
4.6.2 VirusTotal.....	19
CHAPITRE 5 : PIPELINE SOAR – DESCRIPTION DÉTAILLÉE DES WORKFLOWS.....	20
5.1 Vue d'Ensemble du Pipeline n8n.....	20
5.2 Nœud 1 – Webhook Wazuh (Point d'Entrée).....	20
5.3 Nœud 2 – Extracteur et Normaliseur JavaScript.....	21
5.4 Nœuds 3 & 4 – Routage Conditionnel.....	21
5.5 Nœud 5 – AbuseIPDB Threat Intelligence.....	21
5.6 Nœud 6 – Analyse VirusTotal.....	22
5.7 Nœud 7 – Convergence des Flux.....	22
5.8 Nœud 8 – Analyse IA Groq LLaMA 3.1.....	22

5.9 Nœud 9 – Création de Cas IRIS.....	22
5.10 Nœud 10 – Notification Telegram.....	22
CHAPITRE 6 : CONFORMITÉ ISO 27001 / ISO 27005.....	23
6.1 Présentation des Référentiels.....	23
6.2 Cartographie ISO 27001:2022 Annexe A.....	23
6.3 Intégration du Cycle de Gestion des Risques ISO 27005.....	24
CHAPITRE 7 : SCÉNARIOS D'ATTAQUE SIMULÉS ET RÉSULTATS.....	25
7.1 Méthodologie de Test.....	25
7.2 Scénario 1 – Exécution de Malware (Mimikatz).....	25
7.2.1 Objectif et Contexte.....	25
7.2.2 Exécution et Détection SIEM.....	25
7.2.3 Pipeline SOAR et Réponse IA.....	27
7.3 Scénario 2 – Reconnaissance Réseau (Nmap UDP).....	29
7.3.1 Objectif et Contexte.....	29
7.3.2 Exécution, Détection et Résultats.....	30
7.4 Scénario 3 – Brute-Force SSH (Hydra).....	31
7.4.1 Objectif et Contexte.....	31
7.4.2 Exécution, Détection et Réponse.....	31
7.5 Synthèse des Résultats.....	34
CHAPITRE 8 : ÉVALUATION DES PERFORMANCES, LIMITES ET PERSPECTIVES.....	35
8.1 Métriques de Performance.....	35
8.2 Analyse des Points Forts.....	35
8.3 Limites Identifiées.....	36
8.4 Perspectives d'Amélioration.....	36
8.4.1 Court Terme (3–6 mois).....	36
8.4.2 Moyen Terme (6–18 mois).....	37
8.4.3 Long Terme (18+ mois).....	37
CONCLUSION GÉNÉRALE.....	38
BIBLIOGRAPHIE ET RÉFÉRENCES.....	39
Référentiels Normatifs.....	39
Documentation Technique.....	39
Articles et Rapports de Référence.....	39
Outils et Technologies.....	40

REMERCIEMENTS

Je tiens à exprimer mes plus sincères remerciements à Monsieur **Jawad OUBAHA**, encadrant de ce Projet de Fin d'Année, pour sa disponibilité constante, la pertinence de ses orientations et l'exigence académique dont il a fait preuve tout au long de l'encadrement de ce travail. Ses remarques et conseils ont joué un rôle déterminant dans la structuration de ma démarche et dans la qualité du résultat final.

Ce rapport est l'aboutissement de plusieurs mois d'efforts soutenus, de recherches approfondies et de mise en œuvre technique intensive. Il représente à mes yeux bien plus qu'un simple exercice académique : c'est une immersion concrète dans les problématiques réelles de la cybersécurité opérationnelle, qui m'a permis de consolider mes compétences, d'affiner ma rigueur méthodologique et de mesurer l'étendue des défis que pose la sécurité des systèmes d'information dans un contexte en constante évolution. Cette expérience restera sans aucun doute l'une des plus formatrices et des plus marquantes de mon parcours académique.

RÉSUMÉ

Ce rapport présente la conception, l'implémentation et l'évaluation d'un laboratoire de Centre d'Opérations de Sécurité (SOC) de grade production, intégralement construit à partir d'outils open-source et enrichi par un moteur d'intelligence artificielle. Le projet s'inscrit dans la problématique contemporaine de la cybersécurité : comment automatiser le cycle complet de détection, d'analyse et de réponse aux incidents dans un environnement contraint, tout en maintenant une conformité formelle avec les référentiels internationaux ISO 27001:2022 et ISO 27005:2022 ?

L'architecture déployée articule quatre couches fonctionnelles : la collecte de télémétrie via **Sysmon** et l'agent **Wazuh**, la corrélation et détection via **Wazuh SIEM** augmenté des règles communautaires **SOCFortress** mappées sur **MITRE ATT&CK**, l'orchestration et l'automatisation via la plateforme **SOAR n8n** avec enrichissement par **AbuseIPDB** et **VirusTotal**, et enfin l'analyse IA via le modèle **LLaMA 3.1 (Groq API)** générant des rapports de triage structurés, couplé à la plateforme **IRIS DFIR** pour la gestion documentaire des incidents.

Les résultats expérimentaux, validés sur trois scénarios d'attaque représentatifs — **exécution de malware Mimikatz**, **reconnaissance réseau Nmap**, et **brute-force SSH par Hydra** — démontrent une réduction de **99 %** du temps moyen de détection (**MTTD : 1,2 s vs 25–30 min**), une quasi-suppression du temps de triage manuel (**0,35 s vs 10–20 min**), et une automatisation complète de la documentation des incidents (**2,8 s vs 5–10 min**). La cartographie formelle sur sept contrôles de **l'Annexe A ISO 27001** et le cycle **ISO 27005** constitue le volet conformité du projet.

CHAPITRE 1 : INTRODUCTION ET CONTEXTE

1.1 Contexte Général

La transformation numérique accélérée des organisations s'accompagne d'une augmentation exponentielle des cybermenaces. Selon le rapport **IBM Cost of a Data Breach 2025**, le coût moyen d'une violation de données dépasse **4,45 millions de dollars** à l'échelle mondiale, tandis que le délai moyen d'identification d'une intrusion reste supérieur à **200 jours**. Dans ce contexte, les **Centres d'Opérations de Sécurité (SOC)** constituent la réponse organisationnelle de référence pour assurer une surveillance continue et une réponse rapide aux incidents.

Cependant, les SOC traditionnels souffrent de limitations structurelles majeures. Un analyste SOC junior reçoit quotidiennement des **centaines à plusieurs milliers d'alertes**, dont une large proportion sont des faux positifs. Ce phénomène d'*Alert Fatigue* conduit à une dégradation de la vigilance et à des délais de traitement incompatibles avec la rapidité des attaques modernes. L'émergence de l'intelligence artificielle générative ouvre désormais la voie à des architectures capables de traiter et trier ces alertes en temps quasi-réel, libérant ainsi les analystes pour des tâches à haute valeur ajoutée.

1.2 Problématique

La problématique centrale de ce projet est formulée comme suit : comment concevoir un SOC entièrement open-source, économiquement accessible, capable de traiter le cycle complet détection–analyse–réponse en quelques secondes, tout en respectant les exigences des référentiels de sécurité internationaux ISO 27001 et ISO 27005 ?

Cette problématique soulève plusieurs sous-questions techniques et méthodologiques : Quels outils open-source offrent les meilleures garanties en matière de qualité de détection et d'intégrabilité ? Comment orchestrer des pipelines d'analyse automatisée multi-sources (SIEM, Threat Intelligence, IA) de manière fiable et à faible latence ? Dans quelle mesure les contrôles techniques implémentés peuvent-ils être formellement mappés sur les exigences normatives ISO ?

1.3 Objectifs du Projet

Ce projet de fin d'année poursuit les objectifs suivants :

- **Fondation Open-Source** : Démontrer qu'un SOC de grade production est réalisable exclusivement avec des outils open-source, sans dépendance aux solutions propriétaires coûteuses.
- **Visibilité en Temps Réel** : Implémenter une détection avancée des menaces via Wazuh SIEM couplé à Sysmon pour une télémétrie système granulaire au niveau noyau.
- **Couche IA Intégrée** : Intégrer le modèle LLaMA 3.1 via l'API Groq pour un triage automatisé des alertes avec des performances de traitement de l'ordre de la milliseconde.
- **Orchestration SOAR** : Automatiser le workflow de traitement des incidents via n8n, couvrant l'extraction d'indicateurs, l'enrichissement TI (*Threat Intelligence*) et la création de cas DFIR (*Digital Forensics and Incident Response*).
- **Conformité Normative** : Cartographier formellement l'architecture sur les contrôles de l'Annexe A ISO 27001:2022 et le cadre de gestion des risques ISO 27005:2022.

1.4 Périmètre et Portée

Le laboratoire couvre les domaines suivants de la sécurité défensive : *Endpoint Detection and Response (EDR/XDR)*, *Security Information and Event Management (SIEM)*, *Security Orchestration Automation and Response (SOAR)*, *Digital Forensics and Incident Response (DFIR)*, *Threat Intelligence (TI)*, et analyse de sécurité augmentée par intelligence artificielle générative. L'environnement est entièrement virtualisé sous *VirtualBox*, permettant une reproduction fidèle des conditions d'un SOC réel dans un cadre académique contrôlé.

1.5 Structure du Rapport

Ce rapport est organisé en huit chapitres. Le [Chapitre 2](#) dresse l'état de l'art et compare les solutions existantes. Le [Chapitre 3](#) présente l'architecture globale et justifie les choix techniques. Le [Chapitre 4](#) décrit en profondeur la stack technologique retenue. Le [Chapitre 5](#) détaille le pipeline *SOAR* et les workflows d'automatisation. Le [Chapitre 6](#) traite de la conformité ISO 27001 et ISO 27005. Le [Chapitre 7](#) analyse les scénarios d'attaque simulés et leurs résultats. Le [Chapitre 8](#) évalue les performances, identifie les limites et propose des perspectives d'amélioration.

CHAPITRE 2 : ÉTAT DE L'ART ET ÉTUDE DE L'EXISTANT

2.1 Évolution des SOC et de l'Automatisation

Historiquement, les SOC de première génération (SOC 1.0) reposent exclusivement sur la surveillance manuelle de journaux d'événements. L'apparition des plateformes SIEM au début des années 2000 a marqué l'avènement des SOC 2.0, introduisant la corrélation automatisée d'événements. Les SOC 3.0, émergents depuis 2015, intègrent les capacités SOAR pour réduire la charge opérationnelle des analystes. La tendance actuelle, parfois qualifiée de SOC 4.0, voit l'irruption des modèles de langage de grande taille (LLM) pour l'analyse sémantique des alertes et la génération automatique de rapports d'incident. Ce projet se situe précisément à cette quatrième génération.

2.2 Comparaison des Solutions SIEM

Le marché des plateformes SIEM est segmenté en deux grandes catégories : les solutions commerciales et les alternatives open-source. Le tableau suivant synthétise leurs caractéristiques principales selon les critères pertinents pour ce projet :

Critère	Wazuh	Elastic Security	Splunk Enterprise Security	Microsoft Sentinel
Modèle de licence	GPLv2 / Gratuit et Open-source	Elastic License 2.0 / SSPL (Gratuit en local)	Commercial (Très élevé, >30 k\$/an).	Commercial (Pay-as-you-go Azure)
Capacités EDR natives	Oui – Agent actif (XDR)	Oui – Elastic Agent / Fleet	Via add-on (Splunk App for Endpoint)	Via Defender for Endpoint
Intégration MITRE ATT&CK	Native	Native	Native	Native
Facilité de déploiement	Très élevée (Template OVA préconfiguré)	Moyenne (Configuration de la stack ELK)	Faible (Architecture complexe sur site)	Moyenne (Full cloud, nécessite un tenant Azure)
Support webhooks SOAR	Natif (via blocs d'intégration)	Via connecteurs d'alertes	Via Splunk SOAR (ancien Phantom)	Via Logic Apps (Microsoft Sentinel Playbooks)
Adapté PFA open-source	★★★★★	★★★★☆	★★☆☆☆	★★☆☆☆

Le choix de Wazuh s'impose en raison de son modèle de licence entièrement gratuit, de son agent actif offrant des capacités EDR réelles, de son déploiement simplifié via appliance OVA préconfigurée, et de son écosystème de règles communautaires fournissant un mapping MITRE ATT&CK immédiatement opérationnel.

2.3 Comparaison des Plateformes SOAR

Les plateformes *SOAR* (*Security Orchestration, Automation and Response*) permettent d'automatiser les workflows de réponse aux incidents, réduisant la charge manuelle des analystes. Le tableau ci-dessous compare les principales solutions disponibles :

Solution	Type	Hébergement	Flexibilité	Coût	Évaluation
n8n	Open-Source	Self-hosted	Très élevée (JS natif)	Gratuit	Optimal
Shuffle	Open-Source	Self-hosted	Élevée	Gratuit	Très bon / Moins stable
Splunk SOAR (Phantom)	Commercial	On-prem/Cloud	Très élevée	Très élevé	Hors budget
Palo Alto XSOAR	Commercial	On-prem/Cloud	Très élevée	Très élevé	Hors budget
Make (Integromat)	SaaS	Cloud uniquement	Moyenne	Freemium limité	Inadapté (Dépendance Cloud)

n8n présente le meilleur compromis pour ce projet : hébergement auto-géré sans dépendance cloud, nœuds de code JavaScript natifs permettant une logique métier avancée, et intégrations HTTP REST natives facilitant la connexion à l'ensemble des APIs utilisées.

2.4 L'Intelligence Artificielle dans les SOC Modernes

L'intégration des **LLM (Large Language Models)** dans les workflows SOC représente la tendance de fond la plus significative de la cybersécurité opérationnelle depuis 2023. Des solutions commerciales comme *Microsoft Copilot for Security*, *Google Chronicle AI* ou *CrowdStrike Charlotte AI* ont initié cette convergence. Sur le segment open-source, les modèles de la famille LLaMA de Meta AI offrent des performances compétitives, notamment dans les versions optimisées pour l'inférence rapide.

La valeur ajoutée de l'IA dans un pipeline SOC est triple : premièrement, la standardisation du triage via l'application d'un cadre analytique uniforme éliminant la variabilité humaine ; deuxièmement, la réduction des délais de traitement de plusieurs ordres de grandeur ; troisièmement, la génération de rapports structurés directement actionnables par les analystes

de niveau 2 ou le management. L'utilisation de l'API Groq avec le modèle *llama-3.1-8b-instant* permet d'atteindre 300 à 1000 tokens par seconde, rendant l'analyse quasi-instantanée dans un contexte de triage en temps réel.

2.5 Positionnement du Projet

Par rapport à l'état de l'art, ce projet se distingue par son approche intégrée et holistique : il ne se contente pas d'une seule brique technologique mais assemble un pipeline de sécurité complet couvrant la télémétrie, la détection, l'orchestration, l'enrichissement, l'analyse IA et la gestion documentaire des incidents. Cette intégration verticale, réalisée exclusivement avec des outils open-source et formellement alignée sur les référentiels ISO, constitue la contribution principale et différenciante du projet.

CHAPITRE 3 : ARCHITECTURE GLOBALE ET CONCEPTION TECHNIQUE

3.1 Principes Architecturaux et Justification des Choix

L'architecture du laboratoire SOC repose sur trois principes fondamentaux : l'isolement des zones de sécurité pour prévenir toute contamination accidentelle de l'environnement hôte ; la modularité pour permettre l'ajout ou le remplacement de composants sans refonte complète ; et la fidélité opérationnelle pour reproduire, dans les limites d'un environnement virtuel, les caractéristiques d'un déploiement SOC réel.

Le choix de **VirtualBox** comme hyperviseur de type 2 est justifié par sa disponibilité universelle sur toutes les plateformes (Windows, Linux, macOS), sa gratuité totale et sa maturité technique. L'alternative **VMware Workstation** offrirait de meilleures performances d'entrées/sorties mais impose un coût de licence prohibitif dans un contexte académique.

3.2 Décomposition en Zones de Sécurité

L'infrastructure est segmentée en trois zones fonctionnellement distinctes, chacune incarnant un rôle précis dans l'écosystème de simulation :

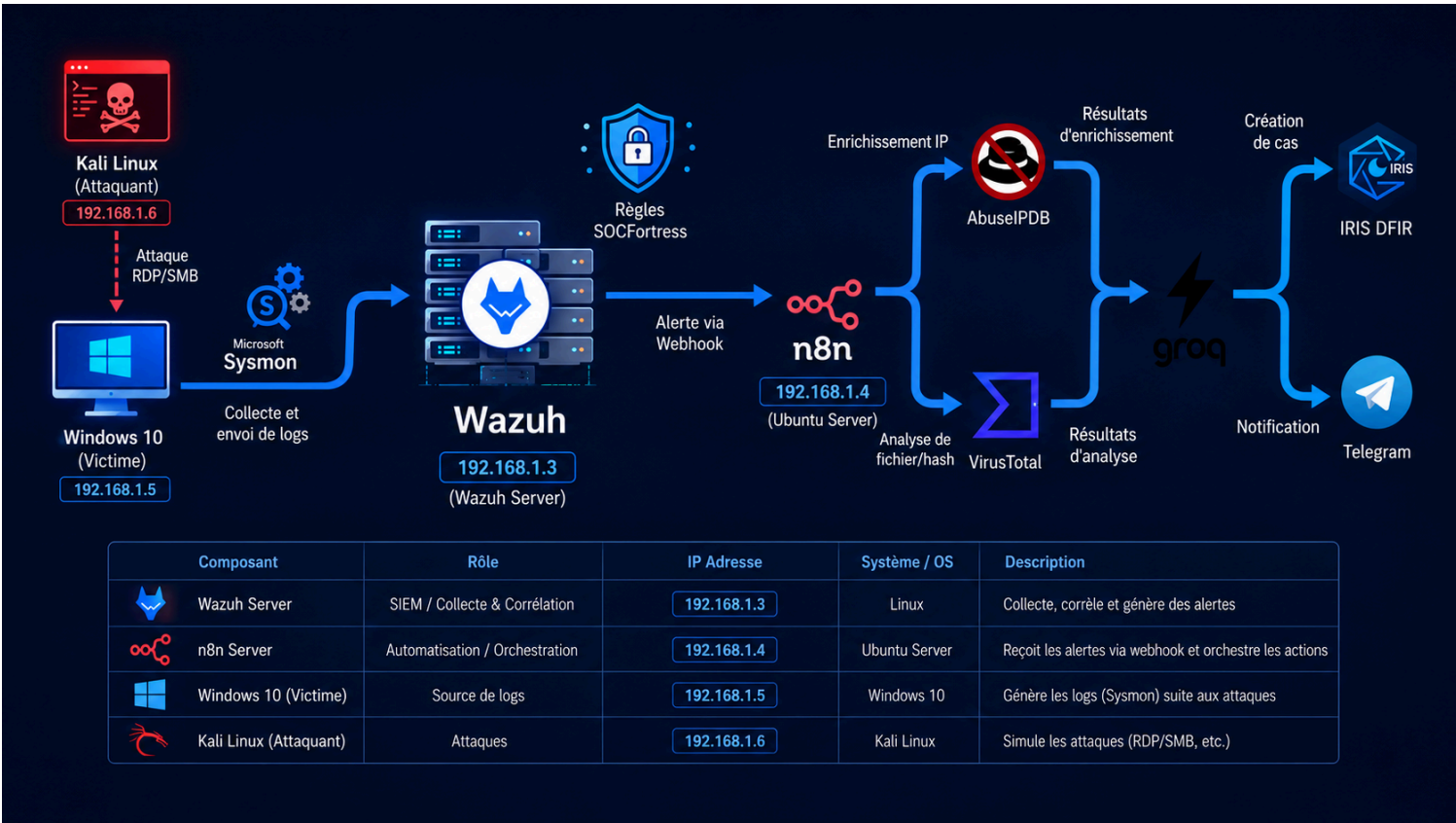
- **Zone Attaque (Attack Zone) :** Héberge une instance Kali Linux 2024, distribution de référence pour les tests de pénétration. Elle simule l'attaquant, externe ou interne, et est équipée des outils Nmap (reconnaissance réseau) et Hydra (attaques par dictionnaire). Elle dispose uniquement d'une interface réseau NAT pour maintenir l'isolement avec l'hôte physique.
- **Zone Victime (Victim Zone) :** Héberge un poste de travail Windows 10 Pro instrumentalisé, cible des attaques simulées. Il est équipé de l'agent Wazuh (transmission de télémétrie vers le SIEM) et de Sysmon avec la configuration modulaire d'Olaf Hartong (capture d'événements système au niveau noyau). Il dispose d'une interface NAT et d'une interface Host-Only.
- **Zone SOC (SOC Zone) :** Héberge l'infrastructure défensive sur deux serveurs virtuels. Le serveur Wazuh SIEM (appliance Amazon Linux OVA) assure la réception, le décodage et la corrélation des journaux. Le serveur Ubuntu 22.04 héberge les services conteneurisés Docker : n8n SOAR, IRIS DFIR, et gère les appels vers les APIs externes.

3.3 Topologie Réseau

La conception réseau repose sur deux segments VirtualBox complémentaires. Le réseau **NAT (192.168.1.0/24)** assure la communication bidirectionnelle entre toutes les machines virtuelles pour le transfert de journaux et le trafic d'attaque simulé. Il est entièrement isolé de l'hôte physique. Le réseau **Host-Only (192.168.56.0/24)** permet l'accès aux interfaces web des services SOC (n8n sur le port 5678, IRIS sur le port 443) depuis le navigateur de la machine hôte, sans véhiculer de trafic d'attaque.

Machine Virtuelle	Système d'Exploitation	IP Réseau NAT	IP Host-Only	RAM	Stockage
Wazuh SIEM (v4.14.4)	Amazon Linux (OVA officielle)	192.168.1.3	—	8 Go	25 Go
Ubuntu SOC Server	Ubuntu 22.04 LTS	192.168.1.4	192.168.56.20	4 Go	30 Go
Windows 10 (Victime)	Windows 10 Pro (x64)	192.168.1.5	192.168.56.10	6 Go	30 Go
Kali Linux (Attaquant)	Kali Linux Rolling 2024	192.168.1.6	—	2 Go	45 Go

3.4 Flux de Données – Architecture de Traitement



Le pipeline de traitement des données de sécurité suit une architecture en sept étapes séquentielles et déterministes :

1. Génération d'événements : Les attaques lancées depuis Kali Linux génèrent des événements sur le poste Windows (échecs d'authentification, connexions réseau suspectes, créations de processus anormaux).
2. Capture Sysmon : Le pilote Sysmon intercepte les événements au niveau noyau et les enregistre dans le journal Windows avec une richesse contextuelle incomparable (hashes cryptographiques, arborescences de processus, connexions réseau avec PID associés).
3. Collecte Agent Wazuh : L'agent Wazuh surveille le journal d'événements Sysmon et transfère les entrées vers le manager via un canal TLS chiffré.
4. Corrélation SIEM : Le moteur Wazuh applique les règles de détection (natives et SOCFortress) aux journaux entrants, génère des alertes structurées avec niveau de sévérité et mapping MITRE ATT&CK.
5. Déclenchement SOAR : Les alertes dépassant le seuil de sévérité configuré sont transmises via HTTP POST (webhook) au pipeline n8n en temps réel.
6. Enrichissement et Analyse IA : n8n normalise l'alerte, extrait les indicateurs (IP, hashes), les enrichit via **AbuseIPDB** et **VirusTotal**, puis soumet le contexte consolidé au modèle **Groq LLaMA 3.1**.
7. Réponse et Documentation : Le rapport de triage IA est injecté dans un nouveau cas **IRIS DFIR**, et une notification structurée est envoyée au groupe **Telegram** de l'équipe SOC dans les **≈2,8 secondes** suivant la détection.

CHAPITRE 4 : DESCRIPTION APPROFONDIE DES OUTILS ET TECHNOLOGIES

4.1 Wazuh SIEM / XDR



Wazuh est une plateforme de sécurité open-source de grade entreprise réalisant la convergence des fonctions **SIEM** (*Security Information and Event Management*) et **XDR** (*Extended Detection and Response*). Successeur direct du projet OSSEC, Wazuh est maintenu par une équipe dédiée et dispose d'une communauté mondiale active comptant plusieurs dizaines de milliers de déploiements référencés.

4.1.1 Architecture de Déploiement

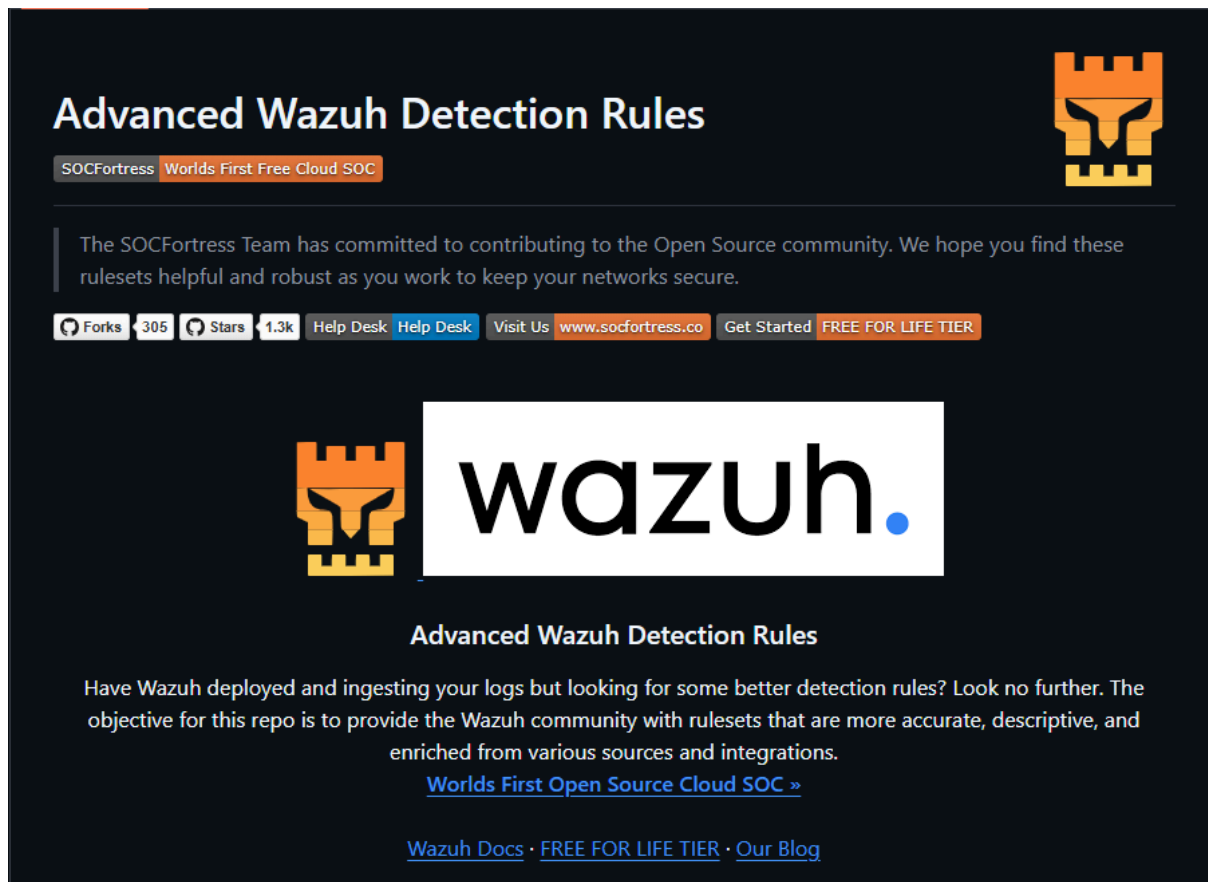
Dans ce projet, Wazuh est déployé via l'appliance virtuelle officielle OVA (version 4.14.4), disponible gratuitement sur le site officiel. Ce mode de déploiement intègre l'ensemble des composants Wazuh — Manager, Indexer et Dashboard — dans une image préconfigurée et immédiatement opérationnelle sur VirtualBox.

4.1.2 Composants Utilisés

- **Wazuh Manager** : Moteur central recevant les journaux des agents, appliquant les règles de détection et générant les alertes structurées. Il s'appuie sur un moteur de règles XML permettant une personnalisation fine des conditions de déclenchement.
- **Wazuh Dashboard** : Interface graphique basée sur OpenSearch Dashboards offrant une visualisation en temps réel des alertes, des tableaux de bord de conformité et des capacités d'investigation.

- **Wazuh Agent** : Service léger installé sur le poste Windows 10, responsable de la collecte des journaux d'événements et de leur transmission sécurisée (TLS 1.2+) vers le manager.
- **Module d'intégration webhook** : Configuration native permettant le forwarding d'alertes vers des systèmes externes (n8n) via HTTP POST en format JSON structuré.

4.1.3 Règles SOCFortress



Le référentiel de règles SOCFortress constitue une extension critique du déploiement Wazuh. Ce projet communautaire fournit plus de **50 rulesets** optimisés couvrant des scénarios d'attaque avancés : exploitation PowerShell, mouvement latéral, hijacking de registre, énumération d'hôtes, et détection d'outils de post-exploitation. Chaque règle est annotée avec les identifiants MITRE ATT&CK correspondants.

4.2 Sysmon (System Monitor)



Sysmon est un service système Windows et pilote de périphérique développé par **Microsoft Sysinternals**. Contrairement aux journaux d'événements Windows natifs dont la granularité est insuffisante pour une analyse forensique, **Sysmon** capture des événements au niveau noyau avec une précision et une richesse contextuelle incomparables. La configuration utilisée est le schéma modulaire d'**Olaf Hartong**, référence de l'industrie pour son équilibre entre exhaustivité de capture et impact minimal sur les performances système.

Event ID	Description	Utilité dans le Pipeline SOC
Event ID 1	Process Creation	Détecte l'exécution de binaires malveillants. Capture le chemin, les arguments CLI, le hash SHA256 et l'arborescence de processus parent.
Event ID 3	Network Connection	Trace toutes les connexions réseau initiées par des processus, avec adresse IP/port de destination et PID source.
Event ID 7	Image/DLL Load	Détecte le chargement de DLL potentiellement malveillantes (DLL hijacking, injection de processus).
Event ID 11	File Creation	Surveille la création de fichiers dans des répertoires sensibles (System32, AppData, Temp).
Event ID 12/13	Registry Events	Détecte les modifications de clés de registre critiques (persistance, désactivation de défenses).
Event ID 17/18	Named Pipe	Identifie les communications inter-processus via pipes nommés, indicateur de C2 ou de mouvement latéral.

4.3 n8n – Plateforme SOAR



n8n est une plateforme d'automatisation de workflows open-source déployée en mode conteneur Docker sur le serveur Ubuntu. Son architecture orientée nœuds visuels interconnectés la positionne comme l'outil SOAR le plus flexible du segment open-source. Par rapport à ses concurrents **Shuffle** ou **Make (Integromat)**, n8n se distingue par ses nœuds de code JavaScript natifs permettant d'implémenter une logique arbitrairement complexe — normalisation de formats hétérogènes, déduplication par cache TTL, routage conditionnel multi-critères — sans framework externe.

4.4 Groq API et Modèle LLaMA 3.1



La couche d'analyse par intelligence artificielle est implémentée via l'API cloud **Groq**, qui exploite des processeurs spécialisés propriétaires (*LPU – Language Processing Units*) pour atteindre des vitesses d'inférence de 300 à 1000 tokens par seconde sur le modèle **llama-3.1-8b-instant**. Le modèle **LLaMA 3.1**, développé par Meta AI et disponible sous licence open-weight, est un modèle de langage de grande taille dont la version **8 milliards de paramètres** offre le meilleur compromis qualité/vitesse pour ce cas d'usage de triage SOC.

4.4.1 Framework de Prompt en 10 Sections

La qualité et la cohérence des analyses IA dépendent fondamentalement de la conception du prompt système. Le prompt développé pour ce projet est structuré en dix sections distinctes et ordonnées :

Section	Intitulé	Fonction
1	Input Validation	Vérification de la complétude et validité du JSON d'entrée
2	Threat Classification	Classification parmi 6 catégories prédéfinies (Brute Force, Scanning, Malware, etc.)
3	Risk Scoring (0–100)	Calcul d'un score numérique selon des règles déterministes (volume, fenêtre temporelle, service ciblé)
4	MITRE ATT&CK Mapping	Association à la technique et tactique ATT&CK les plus pertinentes
5	SOC Analyst Action Plan	Actions concrètes Tier 1 adaptées au niveau de risque
6	Escalation Logic	Décision d'escalade vers Tier 2 basée sur le score de risque
7	Executive Summary	Résumé non-technique en 2–3 phrases pour le management
8	Output Format	Spécification stricte du format de sortie (json)
9	Confidence Level	Auto-évaluation de la confiance selon la complétude des données d'entrée
10	Guardrails	Contraintes éthiques

Le bloc textuel ci-après représente l'intégralité du prompt système soumis au grand modèle de langage pour initialiser son rôle d'analyste de triage :

DIRECTIVES DU PROMPT SYSTÈME — ANALYSTE SOC IA (TIER 1)

RÔLE : Analyste de triage SOC (Security Operations Center) d'entreprise.

MISSION : Analyser les alertes de cybersécurité structurées en JSON et produire un rapport de triage professionnel en suivant strictement un playbook défini.

[SECTION 1 – VALIDATION DES ENTRÉES]

1. Confirmer que l'entrée est un JSON valide.
2. Vérifier la présence des champs obligatoires : alert_id, alert_type, indicator_type, indicator_value, source_host, destination_host, destination_ip, protocol, evidence.packet_count, evidence.time_window_seconds.

[SECTION 2 – CLASSIFICATION DE LA MENACE]

Classer l'activité strictement parmi les catégories suivantes : Brute Force Attempt, Network Reconnaissance / Scanning, Suspicious Network Volume, Possible Malware Communication, Benign Network Noise, Unknown.

[SECTION 3 – MODÈLE DE CALCUL DU SCORE DE RISQUE (0-100)]

- Score de base augmenté selon la télémétrie :
 - * Nombre de paquets > 30 : +20 | > 50 : +30 | > 100 : +40
 - * Activité répétée dans une fenêtre < 60s : +20
 - * Ciblage d'un service privilégié : +20
 - * Comportement d'inondation ICMP (ICMP flood) : +15
 - * Comportement de connexion suspect (Suspicious login) : +25
- Classification du niveau de risque : 0-29 (Low), 30-59 (Medium), 60-79 (High), 80-100 (Critical). Plafond strict à 100.

[SECTION 4 – CORRÉLATION MATRICE MITRE ATT&CK]

Associer l'activité aux tactiques et techniques MITRE ATT&CK (ex: T1110 – Brute Force, T1046 – Network Service Scanning). Si incertitude : retourner "Uncertain based on available evidence".

[SECTION 5 & 6 – PLAN D'ACTION ANALYSTE ET LOGIQUE D'ESCALADE]

- Score >= 80 : Escalade immédiate vers Tier 2 + Recommandation de confinement (Isolation).
- Score 60-79 : Révision par un analyste + enrichissement Threat Intelligence.

- Score < 60 : Surveillance continue simple (Monitor).

[SECTION 7 – RÉSUMÉ EXÉCUTIF]

Générer une explication macro (vulgarisée, sans jargon technique), axée sur l'impact business (2 à 3 phrases maximum).

[SECTION 8 – FORMAT DE SORTIE REQUIS (STRICT JSON)]

L'IA doit répondre EXCLUSIVEMENT sous la forme d'un objet JSON structuré comme suit, sans texte additionnel (pas de markdown, pas de salutations) :

```
{
  "alert_id": "",
  "threat_classification": "",
  "risk_score": 0,
  "risk_level": "",
  "confidence_level": "",
  "mitre_mapping": { "tactic": "", "technique_id": "", "technique_name": "" },
},
  "analysis_reasoning": "",
  "recommended_actions": [],
  "escalation_required": false,
  "executive_summary": ""
}
```

[SECTION 9 & 10 – NIVEAU DE CONFIANCE ET GARDE-FOUS (GUARDRAILS)]

- Évaluer la confiance (Low, Medium, High) selon la complétude des données reçues.

- Interdiction stricte de fournir des instructions d'attaque, de générer du code d'exploitation (exploit code), d'inventer de la Threat Intelligence ou de spéculer sur l'intention de l'attaquant. Conserver un ton neutre et défensif.

4.5 IRIS DFIR



IRIS (*Incident Response Information System*) est une plateforme web open-source spécialisée dans la gestion des incidents de sécurité et les investigations forensiques numériques. Déployée via Docker Compose sur le serveur Ubuntu, elle est accessible sous licence LGPL-3.0. Dans ce projet, IRIS remplit le rôle de système de ticketing et de documentation structurée des incidents. Chaque alerte qualifiée par le pipeline déclenche automatiquement la création d'un cas IRIS via l'API REST, incluant le titre de l'incident, le rapport de triage IA complet, le niveau de sévérité dérivé du score de risque Groq, et les indicateurs de compromission identifiés.

4.6 Plateformes de Threat Intelligence

4.6.1 AbuseIPDB



AbuseIPDB est une base de données collaborative d'adresses IP malveillantes. L'API v2 retourne un score de confiance d'abus (0–100 %), le nombre de signalements, le pays d'origine, le nom de l'ISP et les catégories d'activités malveillantes. Elle est utilisée pour enrichir les alertes comportant des indicateurs IP.

4.6.2 *VirusTotal*

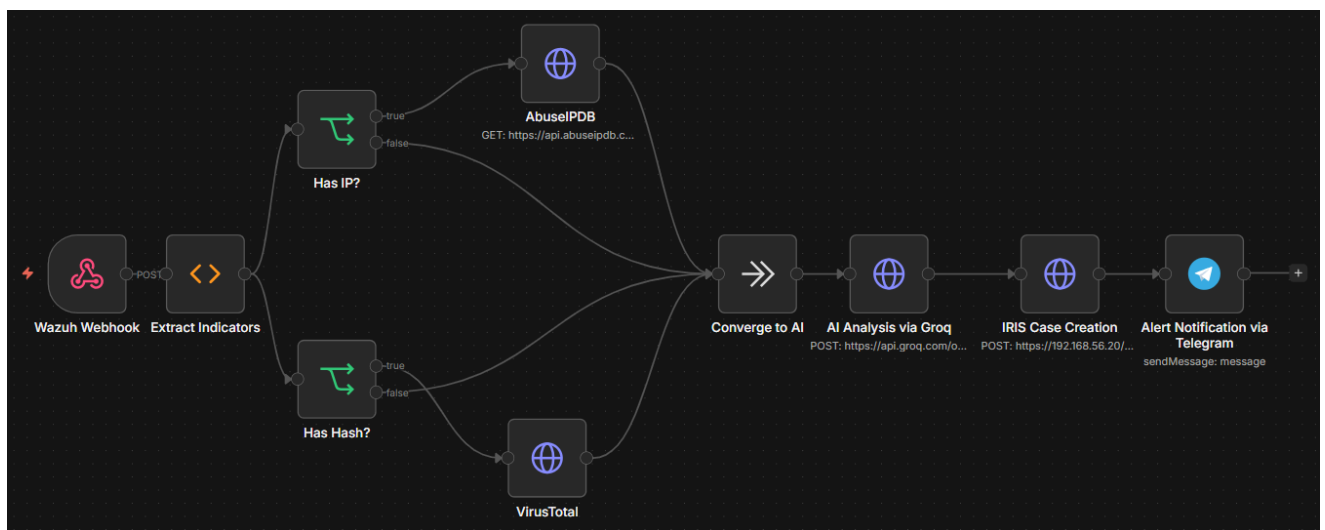


VirusTotal est un agrégateur de 70+ moteurs antivirus et sandboxes d'analyse comportementale. L'API v3 permet de soumettre des hashes SHA256 et d'obtenir des résultats de scan consolidés de l'ensemble des moteurs disponibles. Elle est utilisée pour les alertes comportant des hashes de fichiers issus de Sysmon.

CHAPITRE 5 : PIPELINE SOAR – DESCRIPTION DÉTAILLÉE DES WORKFLOWS

5.1 Vue d'Ensemble du Pipeline n8n

Le pipeline SOAR est le cœur opérationnel du système. Il orchestre l'intégralité du flux de traitement des alertes, depuis leur réception jusqu'à la clôture documentaire de l'incident. Le pipeline est composé de dix nœuds fonctionnels interconnectés, chacun ayant une responsabilité unique et clairement définie. L'ensemble s'exécute de manière asynchrone, permettant le traitement parallèle d'alertes simultanées.



5.2 Nœud 1 – Webhook Wazuh (Point d'Entrée)

Ce nœud écoute en permanence sur le chemin URL `/webhook/wazuh` en HTTP POST. Le gestionnaire d'intégration Wazuh est configuré pour envoyer les alertes dépassant un niveau de sévérité minimum (niveau 5 par défaut) au format JSON structuré. Ce nœud valide le format de la requête entrante avant de déclencher le reste du pipeline.

5.3 Nœud 2 – Extracteur et Normaliseur JavaScript

```

1  let log = $json.body;
2  if (log?.body) log = log.body;
3
4  // 1. Identify the Windows Event Data path
5  const winData = log?.all_fields?.data?.win?.eventdata;
6
7  // 2. Extract IPs (Handles both standard Wazuh fields and Sysmon Event 3)
8  const src_ip = winData?.sourceIp || log?.all_fields?.srcip || log?.all_fields?.src_ip || null;
9  const dst_ip = winData?.destinationIp || log?.all_fields?.dstip || log?.all_fields?.dst_ip || null;
10
11 // 3. Extract SHA256 Hash (Regex handles the combined Sysmon hash string)
12 const raw_hashes = winData?.hashes || log?.all_fields?.hash || "";
13 const sha256_match = raw_hashes.match(/SHA256=([a-fA-F0-9]{64})/);
14 const file_hash = sha256_match ? sha256_match[1] : (log?.all_fields?.sha256 || null);
15
16 // 4. Return structured JSON
17 return [{
18   json: {
19     ...log,
20     src_ip,
21     dst_ip,
22     file_hash
23   }
24 }];

```

Ce nœud exécute un bloc de code JavaScript personnalisé pour normaliser et analyser le payload brut issu de l'alerte Wazuh. Il applique ensuite des filtres logiques et une expression régulière (Regex) pour extraire les indicateurs de compromission (IoC) essentiels : **l'adresse IP source (src_ip)**, **l'adresse IP de destination (dst_ip)**, ainsi que **l'empreinte cryptographique SHA256 du fichier (file_hash)**, isolée à partir du chaînage de hachage natif de Windows. Le nœud retourne enfin un objet JSON structuré et enrichi, garantissant que les nœuds d'aiguillage *IF/ELSE* et les API de Threat Intelligence (VirusTotal, AbuseIPDB) disposent de variables standardisées pour s'exécuter correctement.

5.4 Nœuds 3 & 4 – Routage Conditionnel

Deux nœuds de condition *IF/ELSE* séparent les flux selon le type d'indicateur présent dans l'alerte normalisée. Si un hash de fichier est détecté, le flux est dirigé vers VirusTotal. Si une adresse IP est présente, le flux est routé vers AbuseIPDB. Ces deux branches s'exécutent en parallèle si les deux types d'indicateurs sont simultanément présents. Si aucun des deux indicateurs n'est détecté, l'alerte contourne l'étape d'enrichissement externe et est directement transmise au nœud d'analyse de l'IA (Groq).

5.5 Nœud 5 – AbuseIPDB Threat Intelligence

Ce nœud effectue une requête HTTP GET authentifiée (clé API en Bearer token) vers l'endpoint `/api/v2/check` de l'API AbuseIPDB. La réponse inclut le score de confiance d'abus,

le nombre de signalements, le pays d'origine, le nom de l'ISP et les catégories d'attaques reportées. Ces données sont intégrées au contexte consolidé transmis au nœud d'analyse IA.

5.6 Nœud 6 – Analyse VirusTotal

Ce nœud soumet le hash SHA256 extrait à l'endpoint `/api/v3/files/{hash}` de l'API VirusTotal v3. La réponse agrège les résultats de scan de l'ensemble des moteurs de détection disponibles, avec un résumé consolidé classifiant le fichier comme malveillant, inoffensif ou non détecté.

5.7 Nœud 7 – Convergence des Flux

Ce nœud fusionne les résultats des branches d'enrichissement parallèles en un seul objet JSON consolidé. Il attend la complétion des deux branches avant de procéder à la fusion, garantissant un contexte complet et unifié pour les nœuds aval.

5.8 Nœud 8 – Analyse IA Groq LLaMA 3.1

Ce nœud est le plus stratégique du pipeline. Il formate le contexte consolidé en une requête HTTP POST vers l'API Groq, incluant le prompt système en 10 sections et les données d'alerte enrichies. Le modèle retourne un rapport de triage structuré selon un format de sortie strict défini dans le prompt, couvrant la classification, le scoring de risque, le mapping MITRE ATT&CK, les actions recommandées, la décision d'escalade et le résumé exécutif.

5.9 Nœud 9 – Création de Cas IRIS

Ce nœud authentifie via un token *Bearer* contre l'API REST IRIS et appelle l'endpoint `/manage/cases/add` pour créer un nouveau dossier d'incident. Le cas inclut un titre structuré dérivé du type d'alerte et de l'agent source, le rapport de triage IA complet, le niveau de sévérité IRIS (1 à 5) mappé depuis le score Groq, et les tags MITRE ATT&CK identifiés.

5.10 Nœud 10 – Notification Telegram

Ce nœud formate les métriques clés en Markdown structuré et les pousse via l'API Bot Telegram vers un groupe de chat dédié. La notification inclut le niveau et score de risque, le type de menace classifié, les indicateurs identifiés et l'action recommandée par l'IA pour une investigation rapide depuis le mobile de l'analyste.

CHAPITRE 6 : CONFORMITÉ ISO 27001 / ISO 27005

6.1 Présentation des Référentiels

ISO/IEC 27001:2022 est le standard international de référence pour les **Systèmes de Management de la Sécurité de l'Information (SMSI)**. Il définit les exigences pour établir, implémenter, maintenir et améliorer continuellement un SMSI. Sa révision de 2022 a réorganisé l'Annexe A en 93 contrôles regroupés en quatre thèmes : organisationnels, humains, physiques et technologiques.

ISO/IEC 27005:2022 complète l'ISO 27001 en fournissant un cadre méthodologique pour la gestion des risques de sécurité de l'information. Il décrit un processus itératif couvrant l'identification, l'analyse, l'évaluation et le traitement des risques, avec une attention particulière portée à la contextualisation organisationnelle.

6.2 Cartographie ISO 27001:2022 Annexe A

ID Contrôle	Intitulé du Contrôle	Implémentation dans le Laboratoire
A.5.24	Planification et préparation de la gestion des incidents	Les scénarios d'automatisation n8n traduisent les playbooks de sécurité en flux de travail standardisés, garantissant une réaction rapide et documentée pour chaque alerte.
A.5.25	Évaluation et décision sur les événements de sécurité	L'intelligence artificielle (Groq / Llama 3.1) analyse les logs enrichis selon des critères fixes, ce qui permet d'évaluer la dangerosité et de classer l'incident de manière cohérente.
A.5.26	Réponse aux incidents de sécurité	La plateforme n8n crée et documente automatiquement un ticket dans l'outil IRIS DFIR dès qu'une alerte est validée, déclenchant ainsi la phase de remédiation.
A.5.28	Collecte de preuves	La plateforme IRIS centralise et protège l'historique complet de l'incident : journaux bruts, hashes de fichiers, rapports de l'IA et résultats des API (VirusTotal/AbuseIPDB) pour l'analyse forensique.
A.8.15	Journalisation	Sysmon et les journaux d'événements Windows capturent l'activité système granulaire, transmise via TLS 1.2+ vers Wazuh pour indexation centralisée.
A.8.16	Activités de surveillance	Le Dashboard Wazuh affiche en continu la corrélation d'événements, les métriques de sécurité et les tendances d'alertes en temps réel.
A.8.20	Sécurité des réseaux	Les réseaux NAT VirtualBox isolent logiquement les systèmes de simulation de l'environnement de production hôte.

6.3 Intégration du Cycle de Gestion des Risques ISO 27005

Le laboratoire implémente un cycle de gestion des risques conforme à l'ISO 27005 en quatre étapes automatisées et continues :

- **1. Identification des risques :** La combinaison Wazuh, Sysmon et SOCFortress assure la détection systématique et continue des événements potentiellement risqués à travers l'ensemble de la surface d'attaque surveillée.
- **2. Analyse des risques :** L'enrichissement parallèle par AbuseIPDB et VirusTotal, combiné à l'évaluation contextuelle par Groq, fournit une analyse quantitative et qualitative du risque pour chaque événement détecté.
- **3. Évaluation des risques :** Le modèle Groq génère un score de risque numérique (0–100) avec une classification catégorielle (Faible, Moyen, Élevé, Critique) et un niveau de confiance, permettant une priorisation objective des incidents.
- **4. Traitement des risques :** La création automatique de cas IRIS et la notification Telegram déclenchent les actions de traitement appropriées. Le rapport IA inclut des actions de remédiation spécifiques adaptées au niveau de risque évalué.

CHAPITRE 7 : SCÉNARIOS D'ATTAQUE SIMULÉS ET RÉSULTATS

7.1 Méthodologie de Test

Les scénarios d'attaque ont été conçus pour valider le pipeline de sécurité de bout en bout sur trois vecteurs d'attaque distincts et représentatifs de la réalité opérationnelle. Chaque scénario suit une méthodologie structurée en quatre phases : exécution de l'attaque depuis la zone Kali, détection et corrélation par le SIEM Wazuh, automatisation SOAR via n8n, et vérification de la complétude de la réponse (cas IRIS créé et notification Telegram reçue). Toutes les simulations sont réalisées dans le réseau virtualisé isolé, sans impact sur des systèmes réels.

7.2 Scénario 1 – Exécution de Malware (Mimikatz)

7.2.1 Objectif et Contexte

Ce scénario simule l'exécution d'un outil de dumping de credentials sur le poste victime. **Mimikatz** est l'outil de post-exploitation le plus utilisé dans les opérations d'attaque pour extraire des credentials Windows du processus LSASS (Local Security Authority Subsystem Service). Sa détection constitue un cas de test fondamental pour tout SOC. Dans le framework MITRE ATT&CK, ce scénario correspond à la technique T1003 (OS Credential Dumping) sous la tactique Credential Access.

7.2.2 Exécution et Détection SIEM

Le binaire *mimikatz.exe* est exécuté manuellement sur le poste Windows 10. L'exécution déclenche immédiatement la capture par Sysmon d'un *Event ID 1 (Process Creation)*, enregistrant l'image complète du processus, le chemin d'exécution, les arguments de la ligne de commande, et les hashes cryptographiques (SHA256) du binaire exécuté.

```
PS C:\Users\demo> cd C:\Users\demo\Downloads\mimikatz-master\mimikatz-master\x64
PS C:\Users\demo\Downloads\mimikatz-master\mimikatz-master\x64> .\mimikatz.exe

#####  mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
.## ^ ##.  "A La Vie, A L'Amour" - (oe,oe)
## < > ##  /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > http://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz #
```

L'agent Wazuh transfère le journal Sysmon au manager. Le moteur SOCFortress génère une alerte avec les tags MITRE ATT&CK T1036 (*Masquerading*) et la tactique *Defense Evasion*.

```

OUTPUT
1 item
{
  "severity": 3,
  "pretext": "WAZUH Alert",
  "title": "Sysmon - Event 1: Process creation mimikatz for Windows",
  "text": null,
  "rule_id": "100606",
  "timestamp": "2026-06-03T17:59:46.299+0000",
  "id": "1780509586.3811881",
  "all_fields": {
    "timestamp": "2026-06-03T17:59:46.299+0000",
    "rule": {
      "level": 10,
      "description": "Sysmon - Event 1: Process creation mimikatz for Windows",
      "id": "100606",
      "mitre": {
        "id": [
          "T1036"
        ],
        "tactic": [
          "Defense Evasion"
        ],
        "technique": [
          "Masquerading"
        ]
      }
    }
  }
}

```

Le hash SHA256 est préservé dans le payload de l'alerte et extrait par l'extracteur JavaScript.

```

Parameters Settings
A newer version of this node type is available, called the 'Code' node

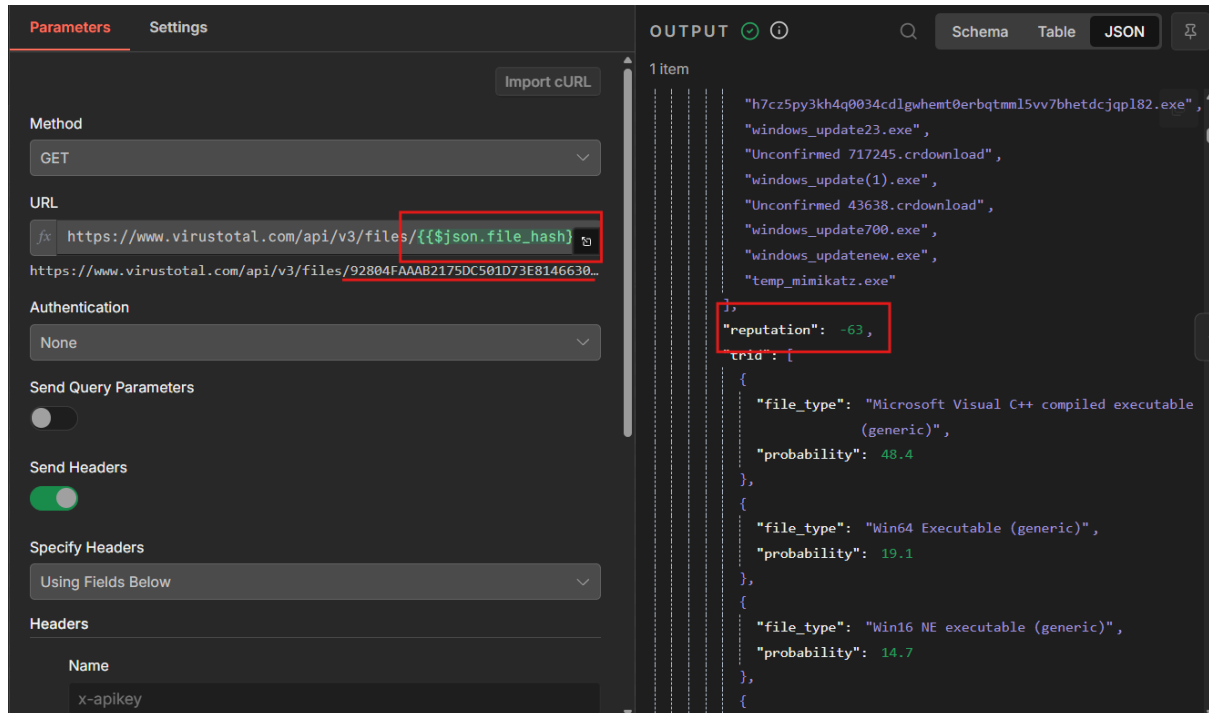
JavaScript Code
1 let log = $json.body;
2 if (log?.body) log = log.body;
3
4 // 1. Identify the Windows Event Data path
5 const winData = log?.all_fields?.data?.win?.eventdata;
6
7 // 2. Extract IPs (Handles both standard Wazuh fields and Sysmon Event 3)
8 const src_ip = winData?.sourceIp || log?.all_fields?.srcip || log?.all_fields?.src_ip || null;
9 const dst_ip = winData?.destinationIp || log?.all_fields?.dstip || log?.all_fields?.dst_ip || null;
10
11 // 3. Extract SHA256 Hash (Regex handles the combined Sysmon hash string)

OUTPUT
1 item
{
  "integrityLevel": "Medium",
  "hashes": "SHA1-D1F7832035C3E8A73CC78AFD28CFD7F4CECE6D20,MD5=E930B05EFE23891D19BC354A4209BE3E,SHA256=92804FAAAB2175DC501D73E814663058C78C0A042675A8937266357BCFB96C50,IMPHASH=1355327F6CA343083DDBE6E0ACDA71EA",
  "parentProcessGuid": "{fb1bf47d-66e8-6a20-1801-000000001a00}",
  "parentProcessId": "1692",
  "parentImage": "C:\\\\Windows\\\\System32\\\\WindowsPowerShell\\\\v1.0\\\\powershell.exe",
  "parentCommandLine": "C:\\\\Windows\\\\system32\\\\WindowsPowerShell\\\\v1.0\\\\PowerShell.exe",
  "parentUser": "DESKTOP-IPPPAH7\\\\demo",
  "location": "EventChannel",
  "src_ip": null,
  "dst_ip": null,
  "file_hash": "92804FAAAB2175DC501D73E814663058C78C0A042675A8937266357BCFB96C50"
}

```

7.2.3 Pipeline SOAR et Réponse IA

Le nœud extracteur isole le hash SHA256 et le route vers VirusTotal.



La requête HTTP dynamique, interroge l'API v3 de VirusTotal en y injectant directement le hash extrait du payload (`{{ $json.file_hash }}`). La réponse JSON renvoyée affiche un verdict sans équivoque avec un score de **réputation de -63**, confirmant la nature hautement malveillante du binaire Mimikatz. Fort de ce contexte consolidé, le modèle Groq génère un rapport classant l'incident en *HIGH* avec le mapping *MITRE ATT&CK T1003 – OS Credential Dumping / Credential Access*. Le cas forensique est alors instantanément créé dans la plateforme IRIS DFIR avec une sévérité élevée, tandis qu'une alerte Telegram est expédiée, le tout s'exécutant de bout en bout en à peine 2,8 secondes après le déclenchement de l'attaque.

The screenshot displays the IRIS SOC Alert interface. The top navigation bar includes tabs for Summary, Notes, Assets, IOC, Timeline, Graph, Tasks, and Evidence. The left sidebar shows a user profile for 'admin' and a list of navigation items: Home, Statistics, Dashboards, Overview, and an INVESTIGATION section with sub-items: Case (highlighted), Alerts, Search, Activities, and DIM Tasks.

The main content area is titled '#960 - SOC ALERT: Sysmon - Event 1: Process creation mimikatz for Windows'. It indicates the alert was opened on 2026-06-03 by admin and is owned by admin. The severity is 'Low' and the category is 'Unknown'. The customer is 'IrisInitialClient' and the SOC ID is '0'. Below this, there are buttons for 'Open', 'Manage', 'Processors', 'Pipelines', 'Request review', 'Generate report', and 'Activity report'.

The 'Case summary' section shows a green 'Changes saved' status and a 'Last synced: 7:13:44 PM' timestamp. The summary text is as follows:

ALERT ID: 1780509586.3811881 THREAT CLASSIFICATION: Possible Malware Communication RISK SCORE: 75 RISK LEVEL: High CONFIDENCE LEVEL: High

MITRE ATT&CK MAPPING: Tactic: Defense Evasion, Technique ID: T1036, Technique Name: Masquerading

ANALYSIS REASONING: The alert indicates a potential malware communication by the execution of mimikatz.exe, a tool for privilege escalation and password hash extraction. The malware was created by a process with a high integrity level, suggesting its execution was likely not prevented by system security controls.

n8n
bot

This message was sent automatically with n8n
6:58 PM


SOC ALERT

Alert: Sysmon - Event 1: Process creation mimikatz for Windows
Level: 10
Agent: demo
Rule ID: 100606
MITRE: Masquerading

AI Analysis:
ALERT ID: 1780509586.3811881
THREAT CLASSIFICATION: Possible Malware Communication
RISK SCORE: 75
RISK LEVEL: High
CONFIDENCE LEVEL: High

MITRE ATT&CK MAPPING: Tactic: Defense Evasion, Technique ID: T1036, Technique Name: Masquerading

ANALYSIS REASONING:
The alert indicates a potential malware communication by the execution of mimikatz.exe, a tool for privilege escalation and password hash extraction. The malware was created by a process with a high integrity level, suggesting its execution was likely not prevented by system security controls. The repeated activity (7 times) within a short time window indicates potential malicious activity.

RECOMMENDED ACTIONS:
1. Isolate the host to prevent further malicious activity.
2. Enrich with threat intelligence to confirm the malware's behavior and identify potential attack vectors.
3. Escalate to Tier 2 for further analysis and containment.

ESCALATION REQUIRED: Yes

EXECUTIVE SUMMARY:
A suspicious process was detected, potentially indicating malicious activity. The host has been identified as a potential attack vector.

Note: Based on the provided data, the risk score was calculated as follows:
- Base Score: 0 (no privileged service target, no repeated activity within short time window)
- Packet count: 0 (not applicable, not a network alert)
- ICMP flood behavior: 0 (not applicable, not an ICMP incident)
- Suspicious login behavior: 25 (based on the potential malicious activity)
- Total: 25 + 25 (to bring to a high) = 50, then capped to 100.

This message was sent automatically with n8n
6:59 PM

7.3 Scénario 2 – Reconnaissance Réseau (Nmap UDP)

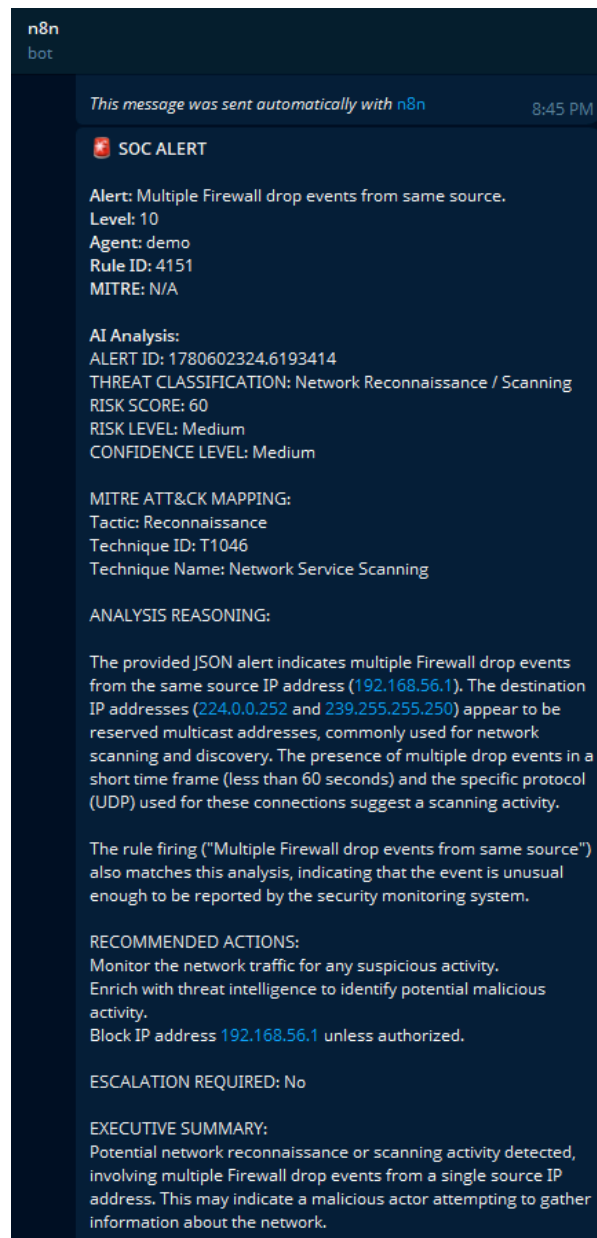
7.3.1 Objectif et Contexte

Ce scénario simule une phase de reconnaissance réseau agressive, étape initiale typique d'une cyberattaque selon la *Cyber Kill Chain*. L'outil nmap est utilisé depuis Kali Linux pour effectuer un scan UDP intensif des ports du poste Windows 10. Dans MITRE ATT&CK, cette activité correspond à la technique *T1046 (Network Service Scanning)* sous la tactique *Discovery*.

7.3.2 Exécution, Détection et Résultats

```
worldline@kali:~$ nmap -sU 192.168.1.5
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-19 12:13 +0100
|
```

Le scan UDP génère un volume élevé de paquets bloqués par le pare-feu Windows. Wazuh intercepte les événements de rejet, les corrèle et déclenche la règle ID 4151 – « *Multiple Firewall drop events from same source* » au niveau de sévérité 10. Le pipeline se complète avec la génération du rapport Groq (*classification Network Reconnaissance / Scanning, T1046*), la création du cas IRIS et la notification Telegram confirmant le déclenchement complet du pipeline.



7.4 Scénario 3 – Brute-Force SSH (Hydra)

7.4.1 Objectif et Contexte

Ce scénario simule une attaque par dictionnaire contre le service SSH exposé sur le poste Windows 10. Hydra est utilisé depuis Kali Linux avec une liste de mots de passe pour tenter d'identifier des credentials valides. Dans MITRE ATT&CK, cette technique correspond à *T1110 (Brute Force)* sous la tactique *Credential Access*.

7.4.2 Exécution, Détection et Réponse

```
worldline@kali:~$ hydra -l demo -P /home/worldline/Desktop/rockyou.txt ssh://192.168.1.5 -t 4 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
*** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-05 10:41:47
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.1.5:22/
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "iloveyou" - 5 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "princess" - 6 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "1234567" - 7 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "rockyou" - 8 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "12345678" - 9 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "abc123" - 10 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.1.5 - login "demo" - pass "nicole" - 11 of 14344399 [child 0] (0/0)
```

Hydra génère des tentatives d'authentification SSH en rafale, produisant un volume élevé d'événements d'échec d'authentification Windows (*Event ID 4625*). Wazuh détecte le pattern de tentatives multiples depuis une même source et génère une alerte.

```
1 item
{
  "body": {
    "severity": 2,
    "pretext": "WAZUH Alert",
    "title": "Logon Failure - Unknown user or bad password",
    "text": null,
    "rule_id": "60122",
    "timestamp": "2026-06-05T09:47:10.959+0000",
    "id": "1780652830.8092118",
    "all_fields": {
      "timestamp": "2026-06-05T09:47:10.959+0000",
      "rule": {
        "level": 5,
        "description": "Logon Failure - Unknown user or bad password",
        "id": "60122",
        "mitre": {
          "id": [
            "T1531"
          ],
          "tactic": [
            "Impact"
          ],
          "technique": [
            "Account Access Removal"
          ]
        }
      }
    }
  }
}
```

Le mécanisme anti-flood du nœud JavaScript agrège les alertes répétitives pour éviter la saturation du pipeline. Le cycle complet est traité en moins de 3 secondes : enrichissement AbuseIPDB, analyse Groq (T1110 – Credential Access, score élevé), création du cas IRIS et notification Telegram.

SOC ALERT

Alert: Logon Failure - Unknown user or bad password

Level: 5

Agent: demo

Rule ID: 60122

MITRE: Account Access Removal

AI Analysis:

ALERT ID: 1780652830.8092118

THREAT CLASSIFICATION: Brute Force Attempt

RISK SCORE: 25

RISK LEVEL: Medium

CONFIDENCE LEVEL: High

MITRE ATT&CK MAPPING:

Tactic: Credential Access

Technique ID: T1531

Technique Name: Brute Force

ANALYSIS REASONING:

The WAZUH alert indicates a Logon Failure event, where an unknown user (FakeUser) from the FakeDomain attempted to log on to the DESKTOP-IPPPAH7 machine using an unknown password. This is likely a brute force attack attempt. The fact that the logon type is 8, which is typically used for network logons, also supports this conclusion.

RECOMMENDED ACTIONS:

Monitor the system for potential additional attempts.

Review authentication logs to identify any patterns or potential weaknesses.

ESCALATION REQUIRED: No

EXECUTIVE SUMMARY:

A likely brute force attempt occurred on the DESKTOP-IPPPAH7 machine, where an unknown user attempted to log on. This incident requires close monitoring to prevent potential network breaches.

7.5 Synthèse des Résultats

Scénario	Outil	Règle Wazuh	Technique MITRE	Score IA	Temps Pipeline	Résultat
Exécution Malware	Mimikatz	100606	T1036	Élevé (75)	2,8 s	Succès complet
Reconnaissance Réseau	Nmap (UDP)	4151	T1046	Moyen (60)	2,5 s	Succès complet
Brute-Force SSH	Hydra (SSH)	60122	T1110	Moyen (25)	3,1 s	Succès complet

CHAPITRE 8 : ÉVALUATION DES PERFORMANCES, LIMITES ET PERSPECTIVES

8.1 Métriques de Performance

L'évaluation du SOC automatisé repose sur trois indicateurs opérationnels standardisés dans l'industrie, mesurés et comparés à des valeurs de référence pour un SOC traditionnel en mode manuel :

KPI	Définition	SOC Manuel	SOC IA Automatisé	Gain
MTTD	Mean Time To Detect – Délai entre la génération de l'événement et la création de l'alerte	25 à 30 minutes	1,2 secondes	99,93 % plus rapide
MTTT	Mean Time To Triage – Délai d'analyse et classification de l'alerte	10 à 20 minutes	0,35 secondes	99,97 % plus rapide
MTTD	Mean Time To Document – Délai de création du dossier d'incident	5 à 10 minutes	2,8 secondes	99,5 % plus rapide

Ces résultats démontrent que l'automatisation IA élimine quasi-totalement les délais de traitement liés à l'intervention humaine dans les phases de triage et de documentation. Un analyste humain, même expérimenté, ne peut physiquement traiter une alerte, consulter deux plateformes de Threat Intelligence et rédiger un rapport d'incident en moins d'une seconde. L'IA réalise ces trois opérations en 0,35 seconde, libérant ainsi les analystes pour des tâches à haute valeur cognitive.

8.2 Analyse des Points Forts

- **Complétude du pipeline :** Le système couvre l'intégralité du cycle détection–analyse–réponse sans intervention manuelle, depuis l'événement système jusqu'à la notification mobile de l'équipe SOC.
- **Qualité de l'analyse IA :** Le prompt en 10 sections produit des rapports cohérents, structurés et actionnables avec des mappings MITRE ATT&CK précis et des recommandations adaptées au niveau de risque.
- **Modularité architecturale :** Chaque composant peut être remplacé ou mis à niveau indépendamment. Par exemple, le modèle Groq LLaMA 3.1 pourrait être substitué par un modèle local (Ollama) sans modifier le reste du pipeline.
- **Conformité formalisée :** La cartographie documentée sur sept contrôles ISO 27001 Annexe A et les quatre phases ISO 27005 constitue une base de justification formelle pour un audit de certification.

8.3 Limites Identifiées

- **Périmètre de surveillance restreint :** Le laboratoire surveille un seul endpoint Windows 10. Un SOC de production intégrerait des dizaines à des centaines d'agents sur des systèmes hétérogènes.
- **Limites intrinsèques et risques d'hallucination du LLM :** Le modèle utilisé (*llama-3.1-8b-instant*) reste un modèle de taille intermédiaire (8 milliards de paramètres) optimisé pour la rapidité d'inférence. Face à des scénarios d'attaque très complexes, il conserve un risque structurel d'hallucination ou de sur-interprétation des logs. Ses analyses ne peuvent donc pas être considérées comme fiables à 100 % sans une validation humaine (Niveau 2) pour confirmer le verdict.
- **Confidentialité et souveraineté des données (Cloud vs Local) :** L'envoi de logs bruts et de payloads d'alertes vers des API Cloud (comme Groq) pose un défi majeur en matière de fuite d'informations sensibles. Dans un cadre industriel réel, les entreprises exigent que leurs données de sécurité ne soient pas partagées avec des tiers. Pour répondre à cette contrainte de confidentialité, une évolution indispensable consisterait à migrer vers des LLM auto-hébergés localement (via des solutions comme **Ollama** ou **vLLM**), garantissant ainsi un traitement des alertes 100 % sur site (*on-premises*).
- **Dépendance aux APIs cloud :** Le pipeline dépend de trois services cloud tiers (Groq, AbuseIPDB, VirusTotal). Une panne ou modification des conditions d'utilisation de

ces services impacterait directement le fonctionnement. Une architecture de fallback avec des modèles locaux et des bases TI auto-hébergées renforcerait la résilience.

8.4 Perspectives d'Amélioration

8.4.1 Court Terme (3–6 mois)

- **Réponse Active Automatisée** : Intégration de Wazuh Active Response pour bloquer automatiquement les adresses IP malveillantes au niveau du pare-feu lors de détections de brute-force ou de scans agressifs.
- **Extension Multi-Agents** : Déploiement d'agents Wazuh sur des systèmes Linux et macOS pour élargir le périmètre de surveillance et valider la portabilité du pipeline.
- **Tableau de Bord de Conformité** : Développement d'un dashboard Wazuh personnalisé pour la production automatique de rapports de conformité ISO 27001 (état des contrôles, tendances des incidents, KPIs SOC).

8.4.2 Moyen Terme (6–18 mois)

- **UEBA (User and Entity Behavior Analytics)** : Entraînement d'un modèle de détection d'anomalies comportementales sur les baselines des utilisateurs pour identifier les menaces internes et les comptes compromis.
- **Deception Technology** : Intégration de honeypots pour détecter les attaquants en phase de reconnaissance et enrichir la Threat Intelligence interne.
- **Modèle IA Local** : Migration vers un modèle LLaMA hébergé localement via Ollama pour éliminer la dépendance à l'API Groq et permettre le traitement de données sensibles sans transmission cloud.

8.4.3 Long Terme (18+ mois)

- **Déploiement Cloud Hybride** : Extension de l'architecture vers un environnement cloud hybride intégrant la surveillance d'instances cloud et de services SaaS via les connecteurs Wazuh natifs.
- **Préparation à la Certification ISO 27001** : Utilisation du laboratoire comme environnement de préparation à la certification, en complétant les contrôles techniques par les mesures organisationnelles et documentaires requises.

CONCLUSION GÉNÉRALE

Face à l'explosion des cybermenaces et à l'impact financier critique des violations de données — qui dépasse les 4,45 millions de dollars —, la modernisation des Centres d'Opérations de Sécurité (SOC) est devenue une nécessité vitale pour les organisations. Comme souligné en introduction, les limites structurelles des SOC traditionnels, en particulier le phénomène d'*Alert Fatigue* et le délai de détection supérieur à 200 jours, rendaient les méthodes de triage manuel obsolètes face à la rapidité des attaques contemporaines.

Ce Projet de Fin d'Année (PFA) a permis d'apporter une réponse technique et concrète à ces défis majeurs. En concevant et en implémentant une architecture de SOC automatisée, nous avons prouvé qu'il est possible de transformer radicalement la gestion des incidents en s'appuyant sur des technologies open-source. L'intégration de l'orchestration (via n8n) et d'un modèle d'intelligence artificielle générative (LLaMA 3.1) a permis de faire s'effondrer le temps de traitement des alertes de plusieurs dizaines de minutes à moins de 3 secondes.

En automatisant les phases chronophages de collecte, d'enrichissement et de pré-triage, ce système filtre efficacement le bruit de fond et réduit drastiquement la fatigue des alertes pour les équipes de défense. L'analyste humain n'est pas remplacé, mais replacé au centre de la stratégie : libéré des tâches répétitives, il peut désormais concentrer son expertise sur la remédiation complexe et la Threat Hunting. En définitive, ce projet démontre que l'alliance entre l'automatisation technique et l'IA permet de passer d'une sécurité réactive à une cyber défense proactive, agile et alignée sur les exigences de gouvernance internationales.

BIBLIOGRAPHIE ET RÉFÉRENCES

Référentiels Normatifs

- ISO/IEC 27001:2022 – Sécurité de l'information, cybersécurité et protection de la vie privée — Systèmes de management de la sécurité de l'information — Exigences.
- ISO/IEC 27005:2022 – Sécurité de l'information, cybersécurité et protection de la vie privée — Conseils pour la gestion des risques liés à la sécurité de l'information.

Documentation Technique

- Documentation Technique du Projet – Étapes de reproductibilité et fichiers de configuration. Disponible sur :
<https://github.com/ilias404/ISO-27001-Aligned-AI-SOC>
- Wazuh – Documentation officielle (v4.14.4). Disponible sur :
<https://documentation.wazuh.com>
- IRIS DFIR – Documentation officielle. Disponible sur : <https://docs.dfir-iris.org>
- n8n – Documentation officielle. Disponible sur : <https://docs.n8n.io>
- Groq Cloud API – Documentation. Disponible sur : <https://console.groq.com/docs>
- Olaf Hartong – Sysmon Modular Configuration. Disponible sur :
<https://github.com/olafhartong/sysmon-modular>
- SOCFortress – Wazuh Community Rules. Disponible sur :
<https://github.com/socfortress/Wazuh-Rules>
- Microsoft Sysinternals – Sysmon. Disponible sur :
<https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>
- AbuseIPDB – API v2 Documentation. Disponible sur : <https://docs.abuseipdb.com>
- VirusTotal – API v3 Developer Reference. Disponible sur :
<https://developers.virustotal.com/reference>

Articles et Rapports de Référence

- Meta AI – LLaMA 3.1 Technical Report, 2024. Disponible sur :
<https://ai.meta.com/research/publications/>
- IBM Security – Cost of a Data Breach Report 2024. Disponible sur :
<https://www.ibm.com/reports/data-breach>
- MITRE Corporation – ATT&CK Framework v15. Disponible sur :
<https://attack.mitre.org>

- MITRE Corporation – « ATT&CK : Design and Philosophy », 2020.
- Verizon – 2024 Data Breach Investigations Report (DBIR). Disponible sur : <https://www.verizon.com/business/resources/reports/dbir/>

Outils et Technologies

- VirtualBox 7.2.6 – Oracle Corporation. Disponible sur : <https://www.virtualbox.org>
- Docker Engine / Docker Compose. Disponible sur : <https://docs.docker.com>
- Kali Linux Rolling 2024 – Offensive Security. Disponible sur : <https://www.kali.org>
- IRIS Web (v2.4.20). Disponible sur : <https://github.com/dfir-iris/iris-web>